PROJECT REVIEW BRIEF

VoltSentry

Inline security proxy for EV charging networks · OCPP 1.6-J

Deepanshu Agarwal · Shubham Krishna · Krish Jairath
Started at Code2Create, ACM-VIT Vellore
github.com/deepanshu214/Voltsentry

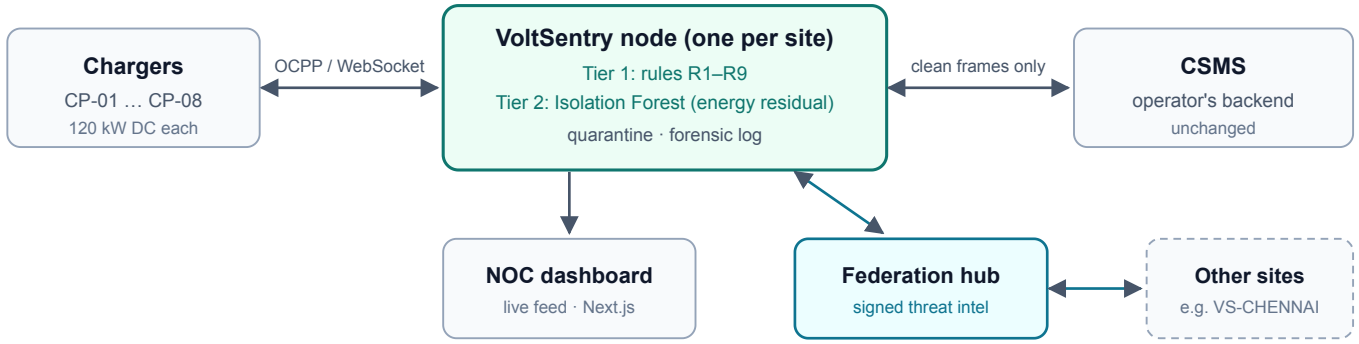
9 + ML	~16 µs	5 / 5	184	2 sites
deterministic rules plus a behavioural model	Tier-1 check per meter frame (mean, 200k frames)	demo attacks detected on the live network	automated tests passing	14 chargers, one federation hub in the demo

1 · The problem

- Public EV chargers talk to the operator's central management system (**CSMS**) using **OCPP**: JSON messages over a WebSocket. Chargers are exposed roadside hardware, often on weakly authenticated connections.
- A compromised charger can **lie**: bill near zero while drawing full power, start and stop in step with others to swing a transformer's load, take over another charger's session, or let a **cloned RFID card** charge two cars at once.
- Cloud platforms analyse this data minutes to hours later, and security hardware cannot be retrofitted into millions of installed chargers.

2 · What VoltSentry does

- **A transparent proxy** between the chargers and the CSMS. Clean traffic passes through untouched; no charger firmware or backend change.
- **Two detection tiers** check every frame before it is forwarded: 9 deterministic rules (Tier 1) and an Isolation Forest model (Tier 2).
- **Active quarantine**: the forged frame is dropped, the charger is told to go `Inoperative` (`ChangeAvailability`) and its socket is closed.
- **A network of sites**: each site runs its own VoltSentry node; nodes share threats through a signed federation hub, so the network sees what no single site can (one card charging in two cities).
- **Real units**: kW, kWh, V, A, Hz and kVA, read off the wire and shown on a live NOC dashboard.
- **Monitor mode** for new sites: detect and report everything, block nothing, until the rules are proven on that site's meters.



Every charger frame passes through the site's VoltSentry node. Sites dial out to the hub; the hub never carries charger traffic.

3 · Detection engine

RULE	TRIPS WHEN	ACTION
`R1_STATE_ORDER`	meter readings or a stop for a session that was never started	log
`R2_PHYSICS`	power > 150 kW, or > 60 kW above 80 % charge (the battery must taper), or negative	**quarantine**
`R3_OSCILLATION`	≥ 6 start/stop transitions across the fleet within 10 s	log (fleet-wide)
`R4_SESSION_UNIQUE`	a second connection claiming a charger that is already connected	refuse socket
`R5_TXN_INTEGRITY`	a meter reading quoting a transaction that is unknown or belongs to another charger	**quarantine**
`R6_METER_FRAUD`	the energy register pulls away from reported power faster than any honest session	**quarantine**
`R7_ELECTRICAL`	reported power ≠ reported voltage × current (beyond 2 kW / 10 %)	**quarantine**
`R8_TAG_CLONE`	an RFID card already in a live session, at this site or another	block card

`R9_THREAT_INTEL`	a card or charger that another site reported as compromised	block / refuse

Tier 2 (behavioural ML). Each session is a 5-number vector `[power_kw, soc, dp_dt, duration_sec, energy_residual_kwh]` scored by an **Isolation Forest** (100 trees), trained on the fleet's whole charging curve and calibrated on separate honest sessions; alert above **0.65**. The key feature is the **energy residual**: the reported energy total minus the integral of reported power over time. Honest sessions keep it near zero; a slow lie makes it climb, even when every single reading is within limits. An offline CUSUM change-detector on the residual corroborates and explains the result.

4 · The five demo attacks

ATTACK	WHAT THE ATTACKER DOES	WHAT CATCHES IT (MEASURED ON THE RUNNING SYSTEM)
Meter spoof	CP-03 reports 5 kW while drawing ~120 kW	R7 on the **first** forged frame: "5.0 kW but 721 V × 166 A = 120 kW"; quarantined
Fleet oscillation	every charger stops and starts together once a second: the transformer swings between 82 % load and none	R3 within ~1.5 s, one fleet-wide alert
Session shadow	a second connection pretends to be live charger CP-01	R4: refused at the handshake (close code 4001)
Subtle drift	under-reports by a compounding 2 % per second, current scaled to match	**No rule fires.** ML crosses 0.65 at ~10 s; R6 quarantines at ~44 s
Card clone	a Chennai charger presents a card that is charging in Vellore	R8 in Chennai (card answered Blocked, never reaches the CSMS); R9 alert in Vellore

5 · Real electrical units

`11 kV feeder → 1250 kVA transformer → 415 V three-phase bus → 120 kW DC chargers → car`

- A house takes **one phase, ~230 V**. A fast charger needs all three phases: **415 V line-to-line = 240 V line-to-neutral**.
- **1250 is kVA** (apparent power), not volts. 8 chargers × 127.7 kVA = 1022 kVA, so the next standard size is 1250 kVA. The 6-charger site gets 1000 kVA.
- Line current I = S ÷ (√3 × V) ≈ 1403 A per phase at full load.
- DC side: 800 V-class pack, ~700 V × ~170 A = 120 kW, inside the 200 A limit of an uncooled CCS2 cable.
- Grid frequency is national; simulated inside the Indian band 49.90–50.05 Hz.

6 · Multi-site network

- Every message is **HMAC-SHA256 signed** with that site's own key; replay protection with rising sequence numbers and a ±120 s time window. Optional TLS (tested with TLS 1.3).
- **Card numbers never leave a site**: only salted hashes are shared.
- Shared blocklist entries expire: chargers after 15 min, cards after 1 h.
- If the hub goes down, **each site keeps protecting itself**; queued intel is delivered when it returns.
- **Monitor mode** (`--mode monitor`): reports what enforce mode *would* do, without blocking or publishing blocklist entries.

7 · Real vs simulated

Real: the OCPP 1.6-J wire format and call correlation, the session state machine, all detection logic (R1–R9, the ML model), unit handling, quarantine, the signed federation, forensic logging and the dashboard.

Simulated: the chargers and cars (a CC-CV battery model with an 800 V pack), and the CSMS (a small mock). The proxy points at any OCPP 1.6 CSMS without code changes.

8 · Tech stack

Proxy, federation, ML	Python 3.11+, asyncio, websockets, scikit-learn, stdlib `hmac` / `ssl`
Dashboard	Next.js 14, TypeScript, Tailwind CSS, Three.js
Protocol	OCPP 1.6-J (JSON over WebSocket)
Tests	pytest: 184 tests, including a hub with two nodes over real sockets

9 · Known limits and next steps

- No real charger or CSMS on the wire yet; next: test against SteVe / CitrineOS.
- ML trained on simulated sessions; next: re-fit and measure false positives on ACN-Data / ElaadNL.
- Charger authentication (OCPP security profiles) is next; TLS already works.
- One hub, no high availability; blocklists are held in memory.
- Dashboard feeds are unauthenticated: keep them on localhost.
- In progress: chargers with several connectors (per-plug sessions).

Possible review questions

Short answers in plain language. Numbers trace to the code, the test suite or measurements on the running two-site network.

CONCEPT

Q1 What problem does VoltSentry solve, in one sentence?

It stops a compromised EV charger from lying to the operator's backend, by checking every OCPP message in real time and cutting the charger off the moment its data is provably false.

Q2 Why a proxy, and not a change to the charger or the CSMS?

Millions of chargers are already installed and their firmware can't be trusted or easily changed, and operators won't rewrite their backend. A proxy drops in between them: the charger is pointed at VoltSentry instead of the CSMS, and neither side notices.

Q3 What is OCPP, and why version 1.6-J?

The Open Charge Point Protocol is the standard language between chargers and management systems. 1.6-J (JSON over WebSocket) is still the most widely deployed version, so it is what a real fleet speaks today. OCPP 2.0.1 is on the roadmap.

Q4 How is this different from a normal firewall or intrusion detection system?

A generic firewall doesn't understand OCPP. VoltSentry checks domain rules: the session order, the physics of a battery (it must taper above 80 %), power = voltage × current, and energy conservation over a whole session. It also acts in the protocol itself, by telling the charger to go out of service.

Q5 What is new about this work?

Inline, OCPP-aware detection with active quarantine; the energy-residual feature that makes slow billing fraud visible from the wire alone; and sites that share threats so the network catches what no single site can, such as one card charging in two cities.

ELECTRICAL UNITS (FACULTY FEEDBACK)

Q6 Homes get 220–230 V. Why does the dashboard show 415–420 V, and what was the "500"?

A house uses one phase: about 230 V between phase and neutral. A 120 kW charger needs all three phases: 415 V between lines, which is 240 V line-to-neutral, the same order as a home. The old "500" was the transformer rating in **kVA**, not volts, and it was wrong: eight 120 kW chargers draw 1022 kVA, so the site needs a 1250 kVA transformer. The dashboard now shows measured volts both ways, amps, Hz and kVA.

Q7 Why is the car side about 700 V?

The charger converts AC to DC for the battery. The simulated cars have an 800 V-class pack, so 120 kW flows at about 700 V × 170 A, inside the 200 A limit of an uncooled CCS2 cable. A 400 V pack would need 300 A.

Q8 Why kVA and not kW for the transformer?

A transformer heats with current, whatever the phase angle, so it is rated in apparent power. kVA = kW ÷ power factor (0.99 for these chargers). Each charger draws 120 kW ÷ 0.95 efficiency + 0.15 kW standby = 126.5 kW = 127.7 kVA.

Q9 Why does the frequency change if one site cannot move the grid?

Exactly because frequency belongs to the whole national grid. The chargers report what they measure at their inlet; in the simulator it wanders inside India's operating band (49.90–50.05 Hz), independent of the site's own load.

DETECTION

Q10 Why two tiers? Why not only rules, or only ML?

Rules are instant, explainable and have no false positives on true invariants, so they catch the loud attacks on the first frame. But a slow, self-consistent lie never breaks a rule. The ML tier exists for that one case. Rules decide quarantines; ML raises an early warning.

Q11 How does R7 catch the meter spoof on the first frame?

One meter message carries power, voltage and current together. Power must equal volts × amps. A charger that edits only the power figure contradicts itself: "5 kW, but 721 V × 166 A = 120 kW".

Q12 What if the attacker also fakes the current, so V × I matches?

That is the subtle drift attack. Every instantaneous reading then agrees, so R7 is silent, but the energy register no longer matches the integral of the reported power. That energy residual climbs; the ML model flags it at ~10 s and R6 quarantines at ~44 s. **Honest limits:** a drift that starts above 80 % charge, where the car already takes 58 kW or less, stays inside the honest taper and is not caught by the model or R6. And if a charger falsified every reading *and* the energy register consistently, nothing on the wire would contradict it; that needs an independent measurement, such as comparing the sum of all chargers with the site's own meter, which is future work.

Q13 Why an Isolation Forest, and not a deep model such as an LSTM?

The input is a five-number vector built around one engineered feature, and the check runs inside the forwarding path. An Isolation Forest is small, fast, needs no attack labels (none exist publicly for OCPP), and its behaviour can be tested. A deep model would add latency for no gain at this input size.

Q14 What data is the model trained on, and why is the threshold 0.65?

On the simulated fleet's whole charging curve: full power to 78 %, the step down to 58 kW by 80 %, and the slow taper to 100 %, in sessions up to 2.5 hours. The scale is then calibrated on 30 separate full honest sessions so the most unusual honest reading scores 0.5, which leaves a margin under 0.65. On 28 more full sessions nothing crossed 0.65, while drift crosses it in about 7–10 s. (The first model saw only full-power charging and flagged every honest car above 80 %; we found that in long test runs and fixed it.) **Honest limit:** it must be re-trained and re-calibrated on real fleet data before production.

Q15 What is your false-positive rate?

Not measured on real data yet. On the simulated fleet, none of 28 full honest sessions (up to 2 hours each) crossed 0.65, and a 25-minute live run, with every car passing through the 80 % hand-off, raised zero alarms. Tier-1 rules check physical and protocol invariants, so an honest charger should never trip them. The real number needs a real dataset (ACN-Data or ElaadNL), which is the next step; monitor mode exists so a site can measure it on its own meters before blocking anything.

Q16 What exactly happens when a charger is quarantined?

The forged frame is dropped so the CSMS never sees it, the proxy sends `ChangeAvailability(Inoperative)` to the charger, the dashboard shows it red at 0 kW, the incident is written to the forensic log, the socket is closed, and other sites are told to refuse that charger for 15 minutes.

Q17 Why does oscillation (R3) only log, and not quarantine?

R3 is a fleet-wide pattern. Quarantining on it would switch off every charger on the site, which is the very outage the attacker wants. It raises one fleet-wide alert for an operator to act on.

NETWORK AND SECURITY

Q18 How do several VoltSentry servers work together?

Each site runs its own node next to its chargers, and every node dials out to a federation hub. The hub relays threats and blocklists and keeps a table of which cards are charging where (as hashes). A charger quarantined in Vellore is refused in Chennai, and a card live in two places at once is blocked. The hub never carries charger traffic.

Q19 What if the hub or the internet link goes down?

Detection never waits on the hub. Each site keeps checking and quarantining on its own, using a local copy of the shared intel. Messages are queued and delivered when the hub returns. We tested this: with the hub stopped, a site still quarantined a meter spoof.

Q20 How are the links between sites secured? Could someone fake a site?

Every message is signed with HMAC-SHA256 using that site's own key, so one leaked key cannot speak for another site. Rising sequence numbers and a ±120 s time window stop replays. TLS encrypts the link. Wrong keys, impersonation and replayed messages were all refused in testing.

Q21 Do sites share customers' card numbers?

No. Sites share only a salted hash of each card, using a salt the hub issues after authentication. That is enough to see the same card at two sites without revealing the number.

Q22 In the demo, why did CP-05's card change to TAG-CP-05-R1?

Once a card has been copied, the copy is as good as the original, so the card number is blocked across the network for an hour. The real customer is issued a replacement card, just as a bank does with a cloned card. Every retry by the attacker is still refused, but it is logged once a minute so the log stays readable.

Q23 Isn't TLS enough? Why do you need detection at all?

TLS proves who you are talking to; it does not prove the charger is telling the truth. A charger with valid credentials can still be compromised and send false meter data. Detection covers that. Charger authentication through the OCPP security profiles is the next addition.

Q24 Could an attacker bypass the proxy, or is the proxy a single point of failure?

In deployment, chargers are configured with the proxy's address and the CSMS accepts connections only from the proxy, so there is no path around it. Today there is one proxy per site; if it stops, that site's chargers lose their link until it restarts. Running several instances per site, with chargers split between them by charger ID, is the planned fix.

Q25 How would an operator roll this out to a new site safely?

Start in monitor mode: every rule and the model run and every threat is reported with what enforce mode *would* have done, but nothing is blocked and nothing is pushed to other sites. Once the false alarms on that site's own meters are known, switch to enforce mode.

IMPLEMENTATION, TESTING AND SCALE

Q26 How did you verify that it works?

184 automated tests cover OCPP parsing and units, the electrical model, the battery, every rule, the ML engine, the full pipeline, and the federation (including a hub with two nodes over real sockets). On the running two-site network we ran normal charging (zero alarms) and all five attacks (all detected).

Q27 What is real and what is simulated?

Real: the protocol handling, all detection logic, quarantine, units, the signed federation and the dashboard. Simulated: the chargers' physics and the CSMS. There is no public labelled set of OCPP attacks, so the attacks are generated by a red-team tool; the CSMS is replaceable by a real one such as SteVe or CitrineOS.

Q28 Is it fast enough to sit inline? Does it scale?

Tier-1 takes about 16 µs per full meter message (mean over 200,000 frames, p99 19 µs). A 10,000-charger operator sending one reading every 10 s produces about 1,000 messages per second, which one instance handles with large headroom. Each site runs its own node, so load is spread by design.

Q29 Who would use this?

Charge-point operators and CSMS vendors. It deploys in front of an existing backend, with no charger or backend change: security added without touching the fleet.

Q30 What are the main limitations, and what comes next?

Not yet tested on real chargers or a real CSMS; the ML model needs real data and a measured false-positive rate; charger authentication (OCPP security profiles) is next; the hub has no high availability; dashboard feeds need authentication. Further out: OCPP 2.0.1 and ISO 15118 Plug & Charge.

ASKED AT THE LAST REVIEW

Q31 What firewall are you using?

Show the Defences tab. VoltSentry is the firewall: an application-level firewall that understands OCPP, built by us, no third-party product. A normal network firewall decides only by IP address and port, so it would let a charger's "5 kW" lie straight through; VoltSentry reads every message and holds back the forged ones before they reach the CSMS. A real site uses both: its own network firewall lets only chargers reach VoltSentry and only VoltSentry reach the CSMS. The tab's diagram shows exactly that, with live counts of messages inspected, forwarded and held back. The laptop demo has no network firewall configured.

Q32 Apart from quarantine, what other safeguards do you use?

Show the Defences tab, scroll down — one card per safeguard with its live count. At the connection: duplicate connections refused (R4), blocklisted chargers refused (R9), oversized messages refused (over 64 KB), malformed connections refused, TLS (available, off in the lab). On every message: forged messages held back, cloned cards answered Blocked. Between sites: messages signed with HMAC-SHA256 per-site keys, replay protection, card numbers shared only as hashes, a blocklist that expires. Operations: monitor mode for new sites, the forensic log, and each site keeps working if the hub is down. **Not built yet** (shown as planned on the tab): charger passwords and certificates, and real console login.